

Critical SQL Injection Leading to Administrative Access – Vulnerability Report

1. Title

Critical SQL Injection Resulting in Unauthorized Administrative Access

2. Vulnerability Description

The application is vulnerable to SQL Injection due to insufficient server-side input validation and the absence of parameterized SQL queries. Successful exploitation resulted in unauthorized administrative access, demonstrating authentication bypass and exposure of sensitive administrative functionality.

3. Target Information

Target Website: <https://www.duhart.com/>

Affected Component: Administrative Login Panel

Affected Path: /admin

Vulnerability Type: SQL Injection

Severity: Critical

4. Steps to Reproduce

- Navigate to the administrative login page.
- Identify the SQL Injection vulnerable parameter.
- Inject a valid SQL payload.
- Submit the crafted request.
- Observe that authentication is bypassed.
- Administrative dashboard is successfully accessed.

5. Impact

- Authentication Bypass
- Unauthorized Administrator Access
- Access to sensitive customer and business information
- Ability to modify or delete records
- Potential complete application compromise

6. Remediation

- Implement prepared statements (parameterized queries).
- Validate and sanitize all user input.

- Apply least-privilege permissions to database accounts.
- Disable verbose SQL error messages.
- Conduct regular security assessments and code reviews.

7. Severity

Critical
OWASP A03:2021 – Injection
CWE-89 – SQL Injection

8. Proof of Concept



Profile Name,
admin

MANAGE ALL SECTIONS

Dashboard

All Store

All Customer

All Industries

All Categories

All Manufacturer

All Product

All Packages

All Offer

All order

All Payment Method

All Testimonial

All Store

Add New

Delete

Show

10

entries

Search:

	Store Name	Email	Package	Notification	Wallet Detail	Package Status	Status	Action
☐			No package	 Notification	 View Wallet		Active	 Edit
			-NA-	 family				
☐			silver	 Notification		Active	Active	 Edit
				 family				
☐			No package	 Notification	 View Wallet		Active	 Edit
			-NA-	 family				
☐			No package	 Notification			Active	 Edit
			-NA-	 family				
☐			No package	 Notification	 View Wallet		Active	 Edit
		0	-NA-	 family				
☐			silver	 Notification	 View Wallet	Active	Active	 Edit